TECHNISCHE OPZET DIGITAAL ONDERTEKENEN

Architectuur, beveiliging, beheer en verbeterpunten van het ondertekensysteem op bnw-ondertekenen.netlify.app.

SAMENVATTING

BNW laat praktijken de leden- en kennismakersovereenkomst digitaal ondertekenen via een persoonlijke link op `bnw-ondertekenen.netlify.app`. BNW vult de praktijkgegevens in, de praktijk leest, tekent en verstuurt; de ondertekende pdf wordt bij BNW opgeslagen met IP-adres en tijdstip, en de praktijk mailt de pdf naar administratie@bnw.nl zolang de e-mailmelding in Netlify nog niet is ingesteld.

Sinds 15 oktober 2026 (versie 2) draait de kern aan de serverkant: links en ondertekende pdf's staan in Netlify Blobs, vijf Netlify Functions regelen aanmaken, ophalen, ondertekenen, downloaden en opschonen. De pagina's zelf blijven statisch.

Onderdeel	Waarde
Hosting	Netlify, project `bnw-ondertekenen`, team Vrone (Pro)
Adres	https://bnw-ondertekenen.netlify.app
Beheer	https://app.netlify.com/projects/bnw-ondertekenen
Opslag	Netlify Blobs, stores `links` en `inzendingen` (regio us-east-2)
Ontvangst	Netlify Forms, formulier `ondertekening`, melding naar administratie@bnw.nl
Broncode	GitHub `carescript87/bnw-ondertekenen`, branch `main`, gekoppeld aan Netlify: elke push rolt automatisch uit
Live sinds	9 oktober 2026, versie 2 op 15 oktober 2026
Eigenaar Netlify-account	Bastiaan Meijer (meijerbastiaan@outlook.com)

ARCHITECTUUR

De site bestaat uit vier statische pagina's, vijf serverfuncties, twee opslagstores en één formulierdefinitie. De functies zijn de enige weg naar de opslag; de pagina's praten alleen met de functies.



Stroom van link tot ontvangst in vier stappen.

De pdf wordt in de browser van de praktijk gemaakt en naar de functie `ondertekenen` gestuurd. Die slaat de pdf op, legt IP-adres, browser en servertijd vast, zet de link op gebruikt en stuurt de gegevens met een pdf-link door naar Netlify Forms voor de e-mailmelding. De praktijk krijgt dezelfde pdf als download.

Pad	Voor wie	Wat het doet
`/`	iedereen	Uitlegpagina zonder functie; verwijst naar administratie@bnw.nl
`/intern-1e2da84950/`	BNW	Linkgenerator: vraagt de BNW-sleutel, kiest overeenkomst, vult 7 praktijkgegevens in
`/ledenovereenkomst/#<token>`	praktijk	Ondertekenpagina ledenovereenkomst
`/kennismakersovereenkomst/#<token>`	praktijk	Ondertekenpagina kennismakersovereenkomst
`POST /api/links`	linkgenerator	Functie `links-maken`: controleert de sleutel en de gegevens, maakt een token, slaat de link op in store `links`
`GET /api/links/:token`	ondertekenpagina	Functie `link-lezen`: geeft de gegevens terug, of `410` verlopen / `409` al ondertekend / `404` onbekend
`POST /api/onderteken/:token`	ondertekenpagina	Functie `ondertekenen`: ontvangt de pdf, slaat op in store `inzendingen`, registreert IP en tijd, meldt aan Netlify Forms
`GET /api/pdf/:token?s=<sleutel>`	administratie (uit de mail)	Functie `pdf-lezen`: levert de pdf, alleen met de juiste pdf-sleutel
functie `opschonen`	planner	Draait elke nacht 02:00 UTC; verwijdert verlopen links en oude inzendingen
`/__forms.html`	Netlify	Verborgen formulierdefinitie waarmee Netlify de velden herkent

TECHNIEK PER ONDERDEEL

- Pagina's: HTML, CSS en JavaScript zonder framework; één bestand per pagina. Lettertype Nunito Sans via Google Fonts, met Arial als fallback.
- Functies: TypeScript (`.mts`) op de moderne Netlify-API, pakketten `@netlify/functions` en `@netlify/blobs`. Gedeelde code in `netlify/functions/_gedeeld.mts`.
- Opslag: store `links` bevat per token een JSON met soort, gegevens, aanmaakdatum, vervaldatum en ondertekentijd. Store `inzendingen` bevat per token `<token>.pdf` en `<token>.json` (metadata: gegevens, IP-adres, browser, servertijd, pdf-sleutel).
- Overeenkomsttekst: overgenomen uit de Word-bestanden van BNW (met de drie correcties van 15 oktober) en als gegevens in de pagina opgenomen.
- Handtekening: een HTML-canvas dat pen-, vinger- en muisbewegingen vastlegt; de handtekening wordt als PNG in de pdf gezet.
- Pdf: jsPDF 2.5.1 bouwt de volledige overeenkomst, de gegevens, beide handtekeningen, datum en tijd van ondertekening en paginanummers.
- Omgevingsvariabelen (scope Functions): `INTERN_SLEUTEL` (sleutel van de linkgenerator), `BEWAARTERMIJN_DAGEN` (standaard 30), optioneel `LINK_BEWAREN_DAGEN` (standaard 2) en `NETLIFY_API_TOKEN` (alleen nodig om ook formulierinzendingen automatisch op te schonen).
- Headers (via `netlify.toml`): `X-Robots-Tag: noindex, nofollow`, `Referrer-Policy: no-referrer`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`.

DE PERSOONLIJKE ONDERTEKENLINK

De link bevat alleen een willekeurig token; de praktijkgegevens staan aan de serverkant. Een link werkt tot en met de vervaldatum en precies één keer.

OPBOUW

`https://bnw-ondertekenen.netlify.app/ledenovereenkomst/#<token>`

- Het token is 32 tekens base64url uit 24 willekeurige bytes (`crypto.getRandomValues`), 192 bits: niet te raden en niet af te leiden uit de gegevens.
- Het token staat achter het `#`. Dat deel van een adres stuurt de browser niet naar de server bij het openen van de pagina; de pagina haalt de gegevens daarna op via `GET /api/links/<token>`.
- Zonder geldig token toont de pagina alleen een foutmelding; de functies controleren het formaat (20 tot 64 tekens, alleen letters, cijfers, `-` en `_`).

VERVALDATUM EN EENMALIG GEBRUIK

- De functie `links-maken` zet de vervaldatum op vandaag plus vijf werkdagen in Nederlandse tijd (zaterdag en zondag tellen niet mee, feestdagen wel).
- De server beslist: na de vervaldatum weigert `link-lezen` met `410` en `ondertekenen` met `410`, ongeacht de klok van de gebruiker. De link is niet te verlengen door iets in het adres aan te passen.

- Na ondertekening zet de server `ondertekend` op het tijdstip; daarna geeft de link `409` en toont de pagina dat de overeenkomst al is ondertekend.
- Verlopen en gebruikte links worden twee dagen later door `opschonen` verwijderd.

WAT DE PRAKTIJK KAN EN NIET KAN

- Kan: gegevens lezen, de overeenkomst lezen, tekenen, versturen, een kopie downloaden.
- Kan niet: gegevens wijzigen, de vervaldatum verlengen, een tweede keer tekenen. Klopt er iets niet, dan maakt BNW een nieuwe link.

BEVEILIGING EN PRIVACY

De links zijn veilig voor hun doel: alleen wie de link heeft, ziet de gegevens; de link verloopt en werkt één keer; alles wat telt, wordt door de server afgedwongen. De handtekening blijft een gewone elektronische handtekening; het bewijs bestaat uit de pdf, het IP-adres, de browser en het servertijdstip.

IP-ADRESSEN

- De link zelf bevat geen IP-adres en onthult er geen. Wie een link opent, ziet niets over de maker of andere bezoekers.
- Bij ondertekening legt de functie `ondertekenen` het IP-adres van de ondertekenaar, de browser (user-agent) en de servertijd vast in de metadata van de inzending en in de formulierinzending (velden `ip_ondertekenaar`, `browser_ondertekenaar`, `ondertekend_op`). Administratie ziet ze in de e-mailmelding en onder Forms.
- Netlify Forms registreerde ook in versie 1 al een IP-adres bij elke inzending (veld `ip`). In versie 2 is dat veld het adres van de functie, niet van de ondertekenaar; gebruik `ip_ondertekenaar`.
- Netlify ziet als hostingpartij het IP-adres van elke bezoeker in eigen logboeken; BNW heeft daar geen toegang toe.
- Het vastleggen van IP-adressen is een verwerking van persoonsgegevens: vermeld het in de privacyverklaring en in het verwerkingsregister, met de bewaartermijn van 30 dagen.

WAT BESCHERMD IS

- Al het verkeer loopt over https; de pdf gaat versleuteld naar de functie en ligt versleuteld in Netlify Blobs.
- Praktijkgegevens staan niet in de link en niet in logboeken of verwijzingen naar andere sites.
- De linkgenerator werkt alleen met de BNW-sleutel (`INTERN_SLEUTEL`), serverkant gecontroleerd in constante tijd. Zonder sleutel kan niemand links maken, ook niet wie het interne pad kent.
- De vervaldatum en het eenmalig gebruik worden door de server afgedwongen.
- De pdf is alleen op te halen met token plus een aparte pdf-sleutel van 144 bits die alleen in de e-mailmelding en onder Forms staat. Blobs zijn nooit rechtstreeks bereikbaar.
- De functie accepteert alleen bestanden die met `%PDF-` beginnen, tussen 1 kB en 4 MB, en alleen bij een geldige, ongebruikte link.

- Pagina's dragen `noindex, nofollow`; `X-Frame-Options: DENY` voorkomt insluiten in een andere site; geen cookies, geen tracking.
- Netlify Forms filtert met Akismet en een honeypot-veld.

WAT NIET BESCHERMD IS

- Iedereen met een ondertekenlink kan tot de vervaldatum de praktijkgegevens lezen en namens de praktijk tekenen. Stuur links alleen naar het e-mailadres van de praktijk.
- Iedereen met de e-mailmelding (of de pdf-link daaruit) kan de pdf openen. Stuur die mail niet door buiten BNW.
- De BNW-sleutel wordt in de browser van de medewerker onthouden (localStorage). Op een gedeelde computer blijft hij achter; wis hem daar na gebruik of werk in een privévenster. Een gelekte sleutel vervangt u in Netlify (omgevingsvariabele `INTERN_SLEUTEL`, daarna opnieuw deployen).
- De handtekening van de Coöperatie staat als afbeelding in de pagina's en de pdf, zoals in de Word-originelen.
- De handtekening is een gewone elektronische handtekening (eIDAS-niveau 1).

PERSOONSGEGEVENS EN OPSLAG

Gegeven	Waar	Hoe lang
Praktijkgegevens (naam, adres, KVK, AGB, naam eigenaar)	store `links`; metadata in store `inzendingen`; formulierinzending bij Netlify	link: tot 2 dagen na vervallen of ondertekenen; inzending: 30 dagen (`BEWAARTERMIJN_DAGEN`); formulierinzending: 30 dagen als `NETLIFY_API_TOKEN` is gezet, anders tot handmatige verwijdering
Ondertekende pdf met handtekening	store `inzendingen`; download bij de praktijk	30 dagen bij Netlify; de praktijk bewaart haar eigen kopie
IP-adres, browser, servertijd	metadata in store `inzendingen`; formulierinzending; functielogboek van Netlify	30 dagen; logboek volgens Netlify (standaard 24 uur tot 7 dagen)
Concept van de BNW-medewerker	niet opgeslagen	n.v.t.

Netlify is een Amerikaanse partij; de opslag staat in regio us-east-2 (Ohio). De verwerking valt onder het Data Processing Addendum van Netlify. Neem Netlify op in het verwerkingsregister van BNW. Sla de pdf's binnen 30 dagen op in het eigen dossier van BNW; daarna zijn ze bij Netlify weg.

BEHEER

E-MAILMELDING INSTELLEN (EENMALIG, NOG TE DOEN)

1. Log in op Netlify en open het project `bnw-ondertekenen`.

2. Ga naar Forms, dan Form notifications, en kies Add notification, Email notification.
3. Vul `administratie@bnw.nl` in, kies het formulier `ondertekening` en sla op.
4. Maak een proeflink, teken en controleer of de mail binnenkomt en of de pdf-link erin de pdf opent. Pas daarna de tekst op de ondertekenpagina aan (de praktijk hoeft de pdf dan niet meer zelf te mailen).

INZENDINGEN BEKIJKEN EN VERWIJDEREN

- Netlify, project `bnw-ondertekenen`, Forms, formulier `ondertekening`: alle inzendingen met gegevens, IP-adres en pdf-link. Ontbreekt een inzending, kijk dan eerst onder Spam.
- De pdf's zelf staan onder Data & Storage, Blobs, store `inzendingen`.
- Opschonen gebeurt automatisch: pdf's en metadata na 30 dagen, links twee dagen na vervallen of gebruik. Formulierinzendingen worden alleen automatisch verwijderd als de omgevingsvariabele `NETLIFY_API_TOKEN` is gezet (een Personal Access Token uit Netlify, User settings, Applications); anders verwijdert u ze handmatig onder Forms.
- De termijn wijzigen: omgevingsvariabele `BEWAARTERMIJN_DAGEN` aanpassen en opnieuw deployen.

TOEGANG EN SLEUTELS

- Netlify-account: team Vrone, eigenaar Bastiaan Meijer. Voeg beheerders van BNW toe als teamlid als zij zelf inzendingen willen bekijken.
- BNW-sleutel: omgevingsvariabele `INTERN_SLEUTEL` in Netlify (Project configuration, Environment variables). Vervangen: nieuwe waarde invullen, opnieuw deployen, nieuwe sleutel aan de medewerkers geven.
- Het interne pad `/intern-1e2da84950/` is zonder sleutel onbruikbaar; het pad geheimhouden blijft wel verstandig.

DE SITE BIJWERKEN

- De broncode staat op GitHub in `carescript87/bnw-ondertekenen`: `bron/` (overeenkomstteksten, templates, logo), `scripts/build.py` (bouwt `site/`), `site/` (de uitgerolde pagina's), `netlify/functions/` (de vijf functies), `test/keten.cjs` (end-to-end-test tegen `netlify dev` of de live site).
- De repository is gekoppeld aan Netlify: elke push naar `main` rolt automatisch uit en is traceerbaar in de Git-historie.
- Een wijziging in de overeenkomsttekst: `bron/led.html` of `bron/ken.html` aanpassen (of een nieuwe Word-versie laten omzetten), `python3 scripts/build.py` draaien, committen, pushen.
- Lokaal testen: `npm install`, een `.env` met `INTERN_SLEUTEL=...`, `npx netlify dev --offline`, dan `node test/keten.cjs`.

BEPERKINGEN EN AANBEVOLEN VERBETERINGEN

Versie 2 van 15 oktober 2026 heeft de verbeterpunten uit versie 1 doorgevoerd. Onderstaande tabel geeft de stand per punt.

Punt	Stand	Opmerking
Links serverkant met willekeurig token, server weigert na vervaldatum	gedaan	store `links`, functies `links-maken` en `link-lezen`; bovendien eenmalig gebruik
Gegevens in de link aanpasbaar	gedaan	de link bevat alleen nog een token; HMAC is daarmee overbodig
IP-adres, user-agent en servertijd bij ontvangst	gedaan	functie `ondertekenen`; velden `ip_ondertekenaar`, `browser_ondertekenaar`, `ondertekend_op`
Automatisch opschonen na bewaartermijn	gedaan voor pdf's, metadata en links	formulierinzendingen alleen met `NETLIFY_API_TOKEN`; zonder token handmatig
Interne pagina zonder wachtwoord	gedaan	BNW-sleutel, serverkant gecontroleerd
Git-repository met Netlify-koppeling	gedaan	GitHub `carescript87/bnw-ondertekenen`, gekoppeld aan Netlify op 15 oktober 2026; automatische uitrol getest
Pdf als bijlage in de mail	open	vraagt een e-maildienst (Resend of SMTP van bnw.nl) en een sleutel; de pdf-link in de melding werkt zonder login
Juridische waarde handtekening	open	voor overeenkomsten met hoger risico een dienst voor geavanceerde of gekwalificeerde handtekeningen gebruiken

Drie tekstfouten uit de Word-bestanden zijn op 15 oktober 2026 hersteld in de live versie: de vertegenwoordiger van de Coöperatie is overal E.I.M. Kunst-Verberne; artikel 1 van de kennismakersovereenkomst verwijst naar artikel 6; de naam is overal Beweegzorg Noord-West. De Word-originelen van BNW bevatten deze fouten nog.